DOM XSS in AngularJS Expression with Angle Brackets and Double Quotes HTML-Encoded

Lab Overview

- **Vulnerability:** DOM-based Cross-Site Scripting (AngularJS Expression Injection)
- **Category:** Client-Side Template Injection
- **Technology:** AngularJS
- **Platform:** PortSwigger Web Security Academy
- **Severity:** High (context-dependent)
- **Status:** Successfully Exploited (after completing the lab)

Description

This vulnerability occurs when an application processes attacker-controlled input as an AngularJS expression instead of treating it as ordinary text.

In this lab, angle brackets (< and >) and double quotes (") are HTML-encoded, which can prevent common HTML injection techniques. However, HTML encoding alone does not prevent injection into an AngularJS expression context.

If untrusted input is evaluated by AngularJS, an attacker may be able to execute JavaScript through expression injection, even when conventional HTML tags cannot be injected directly.

Vulnerability Analysis

The application uses AngularJS to process a user-controlled value within a context where AngularJS expressions are evaluated. Although certain HTML characters are encoded, the underlying expression-processing behavior remains unsafe.

The root cause is the use of untrusted input in an executable template or expression context without appropriate isolation.

Proof of Concept (PoC)

1. Open the assigned PortSwigger lab.

2. Locate the input field or URL parameter processed by AngularJS.
3. Submit a harmless test string and observe how the application renders it.
4. Inspect the page to determine whether the input is interpreted as an AngularJS expression.
5. In the authorized lab, test the lab-specific expression injection technique.
6. Confirm that the intended lab objective is achieved.

Important observation: HTML-encoding angle brackets and double quotes does not neutralize every possible AngularJS expression injection.

The exact expression should be documented from the successful lab execution rather than assumed from the vulnerability title.

Impact

Successful exploitation may allow an attacker to:

- Execute JavaScript within the vulnerable application's origin.
- Manipulate the page or its client-side behavior.
- Access information available to JavaScript in the victim's session.
- Perform actions available to the affected user, depending on application controls.

Remediation

- Never compile or evaluate untrusted input as an AngularJS expression.
- Avoid constructing templates dynamically from user-controlled data.
- Treat user input as data, not executable template content.
- Use secure templating patterns and safe DOM APIs.
- Migrate away from legacy AngularJS where practical.
- Apply a restrictive Content Security Policy as defense in depth.
- Add regression tests for expression injection and DOM-based XSS.

References

- PortSwigger: DOM-based vulnerabilities
- PortSwigger: Cross-site scripting
- OWASP: Cross-Site Scripting Prevention Cheat Sheet

Disclaimer

This report is intended for authorized security testing and educational purposes only. Reproduce the vulnerability exclusively in the designated lab or another environment where you have permission.